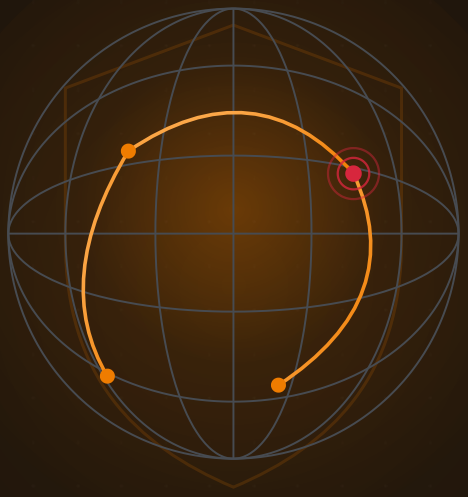
DPG-cyber
TRUSTED • EVERYDAY • EVERYWHERE

EDITION 15
2 NOVEMBER 2026



THREAT PULSE

WEEKLY CYBER THREAT BRIEFING

WEEK IN REVIEW · 26 OCTOBER – 1 NOVEMBER 2026

A maximum-severity flaw in GitLab is being attacked — plus an exploited bug in Drupal online shops, the biggest crypto theft on record and a major Japanese hosting breach.

Prepared by DPG-Cyber
Client threat intelligence

Welcome to **Threat Pulse**, your plain-English weekly round-up of the cyber threats making waves worldwide. This week's standout story is a **maximum-severity flaw in GitLab**, the platform many businesses use to store and build their software, which attackers are already exploiting. We also cover attacks on **Drupal online shops**, a record **$6.3 billion crypto theft** and a breach at hosting provider **GMO Internet**.

AT A GLANCE THIS WEEK

10 /10
Severity of this week's GitLab flaw (maximum)

~2,800
Internet-facing GitLab servers tracked by Shadowserver

$6.3B
Taken from Binance in one attack — a record

THIS WEEK'S HEADLINE THREAT

GITLAB · CVE-2026-97229

Maximum-severity GitLab flaw lets attackers run code on your server — no login needed

10.0 /10 CVSS
CRITICAL

Exploitation: **GitLab has seen attack attempts; US CISA lists it as actively exploited (29 Oct)**

WHAT'S HAPPENING

GitLab is software used to store, manage and automatically build a company's code. A flaw tracked as **CVE-2026-97229**, rated the maximum severity, lets an outsider with **no username or password** run their own commands on the server via a crafted setting. GitLab has seen attack attempts, and on **29 October** US agency **CISA** listed it as known to be exploited.

WHO'S AFFECTED

Organisations that run their **own ("self-managed") GitLab server** on versions before **19.4.2, 19.3.5 or 19.2.8**. Nearly **2,800** exposed servers are tracked. If you use GitLab online, ask your provider to confirm.

WHY IT MATTERS TO YOU

A GitLab server often holds a company's **source code, passwords and keys**. An attacker could steal them, tamper with your software or use it to reach your wider network.

Good news: fixed versions (**19.4.2, 19.3.5 and 19.2.8**) are available now, and GitLab has released detection rules for self-managed servers. If neither you nor your suppliers run GitLab, you need do nothing.

What to do about the headline threat

- ✓ **Ask IT whether you run GitLab** — if so, update to **19.4.2, 19.3.5 or 19.2.8** today.
- ✓ **If it can't be updated yet,** take it off the public internet until it can.
- ✓ **Check for tampering** and change any passwords or keys stored in GitLab if in doubt.

OTHER THREATS WORTH KNOWING ABOUT

HIGH

Drupal online shops are being attacked through a permissions flaw

Drupal has warned that a “highly critical” flaw (**CVE-2026-118539**) in **Commerce Core**, the add-on behind many Drupal web shops, is **already being exploited**. It lets an outsider with no login get around permission checks. Fixes are out (**3.3.13**, or **8.x-2.41** for older versions) and Drupal advises shop owners to check recent orders for anything odd.

Takeaway: if your shop runs on Drupal, ask your web team to update Commerce Core now and review recent orders.

HIGH

Record crypto theft: about $6.3 billion taken from Binance

Analysts at **TRM Labs** and **Chainalysis** link the attack to **TraderTraitor**, a North Korean hacking unit. Around **$6.36 billion** left Binance wallets, most of it in about 20 minutes. Binance has frozen roughly $3 billion, paused withdrawals and says it will cover customer losses; how the attackers got in is still being investigated.

Takeaway: if your business holds crypto, keep little in online wallets and require two people to approve large transfers.

MEDIUM

Japanese hosting giant GMO Internet breached; $50M ransom refused

Attackers got into **Onamae Desktop Cloud**, a hosted-desktop service, and could have planted malware on up to **26,739** customer servers. They demanded about **$50 million**; GMO refused and customer data, including some trading-platform logins, has since been published. Payment details were not exposed. GMO told customers to back up, then disconnect and power down.

Takeaway: if you rent hosted desktops or servers, change passwords, end old sessions and keep a recent offline backup.

Your 3-minute checklist this week

- ✓ Ask IT whether you or a supplier run **GitLab** — and that it has been **updated this week**.
- ✓ If your shop uses **Drupal Commerce**, ask for the update and a review of recent orders.
- ✓ If you hold crypto, keep little in online wallets and require **two approvals** for big transfers.
- ✓ If you use hosted desktops or servers, change passwords and confirm you have a **recent offline backup**.

Threat Pulse is provided by DPG-Cyber for general awareness only and does not constitute specific security or legal advice. Threat details are drawn from reputable public reporting as at 2 November 2026 and may evolve as investigations continue. For guidance tailored to your environment, please contact your DPG-Cyber account team.

BEHIND THE HEADLINES

Why a watchful eye changes the outcome

Every threat in this issue had one thing in common: the damage happens in the **quiet gap between the break-in and the moment someone notices**. Tools alone rarely stop an attack — what limits the harm is continuous monitoring that correlates the signals, spots the intrusion early, and responds before a foothold becomes a crisis.

247 days

Average time for organisations to identify *and* contain a breach

SOURCE: IBM COST OF A DATA BREACH 2026

$4.99M

Global average total cost of a single data breach

SOURCE: IBM COST OF A DATA BREACH 2026

THE WINDOW THAT MATTERS

Intrusion	Foothold	Lateral movement	Impact
the way in	quietly settling in	spreading across systems	data theft / ransomware

The sooner an attack is spotted, the smaller the damage. Closing this window — detecting and responding on the left, long before impact on the right — is the entire job of a Security Operations Centre.

WHAT CONTINUOUS MONITORING QUIETLY DOES

Sees across everything

A SIEM gathers and correlates activity from across your systems, so unusual behaviour stands out instead of hiding in the noise.

Watches around the clock

Attacks don't keep office hours. A SOC means real people monitoring day, night and weekends — not just 9 to 5.

Knows the latest tactics

Fresh threat intelligence — like the GitLab and Drupal attacks in this issue — feeds detection so new tricks are recognised fast.

Acts, not just alerts

Alerts are triaged and investigated by analysts who step in early, turning a would-be incident into a non-event.

CLIENT ACTION OF THE WEEK

THIS WEEK'S FIX

Update GitLab if you run it

Ask your IT team or supplier to move any self-managed GitLab to **19.4.2, 19.3.5 or 19.2.8** today, and confirm in writing that every server has been done.

GOOD HABIT

Run a phishing-awareness drill

Send staff a harmless fake phishing email, then talk through who spotted it and what the warning signs were. A few minutes of practice makes the real thing much easier to catch.

This is the quiet, everyday work behind **DPG-Cyber's SIEM & SOC services** — the same monitoring and response that turns headlines like these into non-events for the businesses we look after. If you're ever curious how it would map to your own environment, we're always happy to talk it through, no pressure — just drop us a line at **hello@dpg-cyber.com**.